

README DEL KIT DE ENCUESTA INTEGRAL DE CIBERSEGURIDAD

Guía Completa de Uso, Implementación y Mejores Prácticas

Versión: 1.0

Fecha: Enero 2026

Público: Responsables de ciberseguridad, CISOs, auditores, consultores de seguridad

Propósito: Guía integral explicando qué es el kit, cómo usarlo, y cómo extraer máximo valor

¿QUÉ ES ESTE KIT DE ENCUESTA?

Definición

El **Kit de Encuesta Integral de Ciberseguridad** es un conjunto profesional, exhaustivo y estructurado de instrumentos de evaluación diseñados para **medir, monitorizar y reportar la madurez de ciberseguridad** de una organización.

No es:

-  Un cuestionario genérico de compliance
-  Una lista de control de auditoría tradicional
-  Un framework de remediación paso-a-paso

Sí es:

-  Un sistema integral basado en metodología GQM + PRAGMATIC
-  Alineado a CIS Controls v8.1, NIST CSF 2.0, NIS2, GDPR, ISO 27001
-  Profesional, literario, irónico pero riguroso
-  Orientado a métricas accionables y trazables
-  Escalable (PYME a empresa crítica)

COMPONENTES DEL KIT

Los 6 Documentos que Conforman el Kit

DOCUMENTO 1: Marco Integrativo GQM + PRAGMATIC [174]

- Metodología GQM (Goal-Question-Metric) explicada
- 9 criterios PRAGMATIC (Predictivo, Relevante,...)
- Proceso de diseño integrado en 5 pasos
- 2 ejemplos concretos (MTTD, Vulnerabilidades)
- Alineación a objetivos nacionales España 2024-26
- Checklist de validez de métricas

USO: Leer PRIMERO para entender filosofía
CUANDO: Semana 1 de implementación
AUDIENCIA: CISO, Security Managers, Architects

DOCUMENTO 2: Matriz de Evaluación PRAGMATIC Completa [175]

- 45+ indicadores de ciberseguridad detallados
- 8 módulos temáticos (GRC, IDENTIFY, IAM, etc)
- Evaluación exhaustiva de PRAGMATIC (9 criterios)
- Score de cada indicador (0-3 escala)
- Recomendaciones (✓ IMPLEMENTAR / ⚠ / ✗)
- Fichas técnicas con fórmulas de cálculo
- Plan de implementación faseado (3 fases)

USO: Seleccionar indicadores según fase
CUANDO: Semana 2 (selección inicial)
AUDIENCIA: CISO, Metrics Team, Audit

DOCUMENTO 3: Mapeo Detallado a Requisitos Normativos [188]

- Matriz mostrando alineación CIS ↔ NIST ↔ NIS2
- Mapping completo a GDPR, ISO 27001, regulaciones
- Requisitos españoles (INCIBE, CCN, ENS, LOPD)
- Artículos específicos de cada normativa
- Criticidad de cumplimiento (OBLIGATORIO vs Rec.)
- Notas de multas potenciales por incumplimiento

USO: Validar qué normativas aplican a organización
CUANDO: Semana 3 (antes de ejecutar encuesta)
AUDIENCIA: CISO, Legal, Compliance Officer

DOCUMENTO 4: Plantilla Excel para Cálculo IGM & ROI [189]

- 6 hojas integradas (Instrucciones, Entrada datos, Cálculo IGM, Cálculo ROI, Dashboard, Benchmarks)
- Automatización de cálculos PRAGMATIC
- IGM (Índice Generación Métricas): 0-100%
- ROI ciberseguridad: 3-year model
- Benchmarks sectoriales España
- Sensibilidad análisis (si varían asunciones)

USO: Introducir datos; generar reportes
CUANDO: Semana 4 (post-encuesta)
AUDIENCIA: CISO, CFO, Finance Team

DOCUMENTO 5: Plantilla Reporte Ejecutivo PowerPoint [190]

- 15-18 diapositivas profesionales
- Estado ejecutivo, KPI dashboard, hallazgos
- Análisis detallado por módulo CIS
- Riesgos críticos con planes de acción
- Roadmap de 6 meses
- Presupuesto, ROI, recomendaciones board
- Notas para presentador (timing, tono, Q&A)

USO: Presentar resultados a board/ejecutivos

CUANDO: Semana 6-8 (presentación formal)

AUDIENCIA: Board, C-Suite, Audit Committee

DOCUMENTO 6: README (Este documento)

- Guía integral del kit
- Cómo usar cada documento
- Mejores prácticas
- Troubleshooting
- Roadmap de implementación
- FAQ y contactos

USO: Referencia durante todo el proceso

CUANDO: Continuamente durante 6-12 meses

AUDIENCIA: Todos los stakeholders

CÓMO USAR ESTE KIT - ROADMAP DE IMPLEMENTACIÓN

FASE 0: PREPARACIÓN (Semanas 1-2)

Actividad Principal: Entender framework y alinear internamente

Semana 1:

- └ Leer Documento 1 (Marco GQM + PRAGMATIC)
 - └ Tiempo: 4 horas
 - └ Notas: Tomar apuntes de conceptos clave
 - └ Objetivo: Entender filosofía de métricas
- └ Leer Documento 3 (Mapeo Normativo)
 - └ Tiempo: 2 horas
 - └ Objetivo: Identificar normativas que aplican
 - └ Resultado: Lista de regulaciones obligatorias para org.
- └ Crear equipo de trabajo
 - └ CISO (líder)
 - └ Security Manager (operacional)
 - └ Finance/Controllers (ROI)
 - └ Compliance Officer (regulatorio)
 - └ Especialistas técnicos por módulo (SIEM, IAM, etc)

Semana 2:

- └ Reunión de alineamiento: Revisar alcance del proyecto
 - └ Preguntas clave:
 - └ ¿Cuál es el objetivo? (diagnóstico, compliance, ROI?)
 - └ ¿Qué módulos CIS son críticos para nosotros?
 - └ ¿Cuál es el horizonte? (1 año, 3 años?)
 - └ ¿Quién es el patrocinador ejecutivo?
 - └ ¿Budget disponible?
- └ Adaptar documentos a contexto organizacional
 - └ Incluir logo, branding, nombres reales
 - └ Ajustar ejemplos a industria específica
 - └ Localizar monedas a EUR (si es España)
- └ Planificar comunicación
 - └ Email de lanzamiento a stakeholders
 - └ FAQ preparadas
 - └ Calendar de hitos importantes

FASE 1: EJECUCIÓN DE ENCUESTA (Semanas 3-5)

Actividad Principal: Recopilar datos de encuesta distribuida a equipos

Semana 3:

- Customizar encuesta (si es necesario)
 - └ Si encuesta propia: mapear a Documento 2
 - └ Si usar Documento 2 directamente: copiar preguntas
 - └ Crear en plataforma: Microsoft Forms, Qualtrics, SurveyMonkey
 - └ Incluir instrucciones claras (tono irónico pero profesional)
- Distribuir encuesta
 - └ Email de lanzamiento (explicar objetivo no es "culpa")
 - └ Recordatorios automáticos Day 3, Day 7, Day 10
 - └ Especificar "Responsable" por área (no anónima)
 - └ Target: Plazo 7 días para completion
- Sesiones de calibración (opcional pero recomendado)
 - └ 30-min sesiones con líderes por módulo
 - └ Aclarar qué significa "Nivel 2 vs Nivel 3" en escala
 - └ Revisar evidencia (logs, documentación)
 - └ Nota: Conviene en person o video call, no email

Semana 4:

- Cerrar encuesta (después de 7 días o X% completion)
 - └ Si <60% completion → extender 3 días más
 - └ Si <40% → contactar líderes de área directamente
- Revisión de datos
 - └ Validar que scores están en rango 0-5 (o escala usada)
 - └ Identificar datos faltantes (blanks)
 - └ Identificar outliers (1 persona dijo "5", todos otros "1")
 - └ Nota: Esto es NORMAL; documentar para análisis
- Sesiones de validación (CRÍTICO - do not skip)
 - └ Reunión de 2 horas: CISO + responsables de módulo
 - └ Presentar resultados preliminares
 - └ Discutir interpretaciones de pregunta si hay discrepancias
 - └ Resolver puntuaciones divergentes
 - └ Documento: Acta de calibración final
- Entrada de datos a Excel (Documento 4)
 - └ Transferir scores finales validados
 - └ Triggerear cálculos automáticos (IGM, ROI)
 - └ Revisar sumas y promedios

Semana 5:

- Análisis detallado
 - └ ¿Cuál es IGM global? (target: >70%)
 - └ ¿Qué módulos están rezagados? (focus áreas)
 - └ ¿Cuáles son los 5 indicadores de mayor criticidad?
 - └ ¿Dónde hay mayor brecha vs benchmark?
- Identificación de riesgos
 - └ Para cada indicador con score <2.0:
 - └ ¿Es realmente un riesgo o simplemente no implementado?
 - └ Si riesgo: ¿cuál es impacto si no se remedia?
 - └ Si no implementado: ¿es obligatorio regulatoriamente?
 - └ ¿Hay plan de remediación?
- Draft de recomendaciones
 - └ Priorizar por: criticidad + facilidad de remediación
 - └ Crear plan de acción inicial

└ Estimar presupuesto (usando Documento 4 helpers)

FASE 2: REPORTE Y PRESENTACIÓN (Semanas 6-8)

Actividad Principal: Comunicar resultados a ejecutivos y board

Semana 6:

- └ Preparar presentación ejecutiva
 - └ Usar Documento 5 (PowerPoint template)
 - └ Customizar con datos finales
 - └ Incluir ejemplos reales de riesgos
 - └ Grabar demos (si sistema nuevo con SIEM/dashboard)
- └ Draft report (documento formal)
 - └ Executive Summary (1 página)
 - └ Hallazgos por módulo (8-12 páginas)
 - └ Riesgos críticos (2-3 páginas)
 - └ Recomendaciones prioriz (2 páginas)
 - └ ROI/Presupuesto (1-2 páginas)
 - └ Apéndices (encuesta completa, datos brutos, benchmarks)
- └ Revisión interna
 - └ CISO revisa & aprueba mensaje
 - └ Finance/CFO revisa números
 - └ Legal/Compliance revisa declaraciones regulatorias
 - └ Incorporar feedback

Semana 7:

- └ Presentación a CISO + executive sponsor
 - └ Asegurar alineamiento en mensajes clave
 - └ Anticipar preguntas difíciles
 - └ Preparar respuestas (con datos)
- └ Preparar board book
 - └ Resumen ejecutivo (1-2 páginas)
 - └ Presentación PowerPoint (15-18 slides)
 - └ Anexo técnico (Documento 2 + datos brutos)
 - └ FAQ antici (ver sección FAQ de este README)
- └ Coordinar logística
 - └ Agendar en calendarios de directores (mínimo 2 semanas antes)
 - └ Confirmar asistencia: CFO, COO, Board audit committee
 - └ Ubicación: Sala ejecutiva, videocall setup, etc.

Semana 8:

- └ Presentación a Board/Audit Committee
 - └ Duración: 25 minutos presentación + 5 minutos Q&A
 - └ Objetivo: Aprobación de recomendaciones/presupuesto
 - └ Resultado esperado: Votos para Plan de Acción
- └ Documento formal distribuido
 - └ Acta de reunión con decisiones
 - └ Confirmación de presupuesto
 - └ Designación de responsables
 - └ Timeline de implementación
- └ Kick-off de remediación
 - └ Primera reunión con equipo de ejecución
 - └ Distribuir Plan de Acción con hitos
 - └ Asignar propietarios por iniciativa

FASE 3: MONITOREO CONTINUO (Meses 3-12+)

Actividad Principal: Mantener métricas vivas y mejorar continuamente

Frecuencia MENSUAL (Security team reporting):

- └ Actualizar indicadores principales (MTTD, MFA, vulns críticas)
- └ Verificar avance contra roadmap (% completación)
- └ Identificar obstáculos (bloqueadores)
- └ Ajustar plan si es necesario

Frecuencia TRIMESTRAL (CISO + Board audit committee):

- └ Re-ejecutar encuesta completa (o muestra de indicadores)
- └ Calcular nuevo IGM
- └ Actualizar dashboard ejecutivo (Documento 5 template)
- └ Presentar progreso formal a board
- └ Decisiones sobre presupuesto adicional si requerido

Frecuencia SEMESTRAL (Governance review):

- └ Revisar effectiveness del framework de indicadores
- └ ¿Indicadores son accionables? (si no → retirar)
- └ ¿Hay nuevas normativas? (adaptar Documento 3)
- └ ¿Benchmarks han cambiar? (actualizar Documento 4)

Frecuencia ANUAL (Auditoría externa):

- └ Auditorador independiente valida métricas
- └ Verifica que cálculos están correctos
- └ Valida evidencia detrás de scores
- └ Emite certificado (si es política organizacional)

HERRAMIENTAS RECOMENDADAS:

- └ Dashboard: Power BI, Tableau, o Google Sheets
 - └ Graficar tendencias (IGM últimos 4 trimestres)
 - └ Alertas automáticas si métrica cae >5%
- └ Colaboración: Confluence, OneNote
 - └ Documentar notas de calibración
 - └ Mantener FAQ viva
 - └ Cambios en metodología
- └ Data warehouse: SQL, Data lake
 - └ Integrar con SIEM, scanner, IAM logs
 - └ Evitar re-ingreso manual de datos
 - └ Automatizar cálculos donde sea posible

MEJORES PRÁCTICAS

1. Asegurar Objetividad (No Sesgo)

RIESGO: "La gente siempre se califica a sí misma como nivel 5"

SOLUCIÓN:

- └ Calibración con evidencia (ver logs, documentación)
- └ Sesiones de grupo (pares se cuestionen entre sí)
- └ Mapeo a PRAGMATIC (¿Realmente es "Oportuno"? No si manual)
- └ Auditoría externa (cada año para validación)

RIESGO: "Diferentes personas interpretan 'Nivel 3' diferente"

SOLUCIÓN:

- └ Crear diccionario de comportamientos por nivel
 - └ Nivel 1: "Ad Hoc" - no documentado, inconsistente
 - └ Nivel 2: "Definido" - documentado, sigue proceso
 - └ Nivel 3: "Manageable" - automatizado, monitoreado
 - └ Nivel 4: "Optimizado" - continuo mejora, benchmark
- └ Ejemplos reales (case studies) por industria
- └ Sesiones de calibración antes de encuesta

2. Comunicación Clara (Tono Irónico pero No Defensivo)

PRINCIPIO: Las métricas bajas NO significan "mala seguridad"
Significan "oportunidad de mejora"

LENGUAJE RECOMENDADO:

- ✗ EVITAR: "El equipo de seguridad está fracasando"
"Vulnerabilidades sin parchear es negligencia"
"Contraseñas débiles demuestran falta de capacitación"
- ✓ USAR: "Oportunidad identificada: acelerar remediación de críticas"
"Gap detectado en SIEM tuning; plan de mejora en progreso"
"Conciencia de seguridad mejorando (15% → 8% phishing en 4m)"

HUMOR CONTEXTUAL:

- └ "Si MTTD es 24 horas, los atacantes tienen casi un día completo"
 - └ Reconoce problema SIN culpar
- └ "SIEM con 32% false positives es como alarma de humo en cocina"
 - └ Metáfora relacionable
- └ "Sin SBOM, sabemos tanto sobre software como auditor de TI en 2015"
 - └ Autodestructive (inclusive)

3. Trazabilidad Regulatoria Explícita

PARA CADA INDICADOR, DOCUMENTAR:

1. ¿QUÉ NORMATIVA REQUIERE ESTO?
 - └ NIS2 Art. 20? GDPR Art. 32? ISO 27001 A.12.4?
 - └ Si NINGUNA: ¿por qué lo medimos? (respuesta válida: "best practice")
2. ¿CUÁL ES EL RIESGO DE NO CUMPLIR?
 - └ Multa potencial (€X)
 - └ Reputacional (% customers puede abandonar)
 - └ Operacional (horas downtime si brecha)
3. ¿CÓMO PROBAMOS QUE CUMPLIMOS?
 - └ Evidencia (logs, documentación, auditoría)
 - └ Responsable de mantener evidencia
 - └ Auditor que lo verifica

EJEMPLO:

Indicador: MFA Coverage (Target: 100% admin, >95% usuarios)
Normativa: NIS2 Art. 20(2) "Multi-factor authentication" GDPR Art. 32 "Technical security measures" ISO 27001 A.9.2 "User authentication"
Riesgo: Multa GDPR €500k-€20M si brecha por credential Multa NIS2 €250k-€10M por incumplimiento
Evidencia: Azure Entra ID report "MFA enabled" monthly Screenshot reports (audit trail) Audit externo anualmente
Propietario: Identity Access Manager Auditor: Internal audit + CISO

4. Involucración de Ejecutivos (No Delegación)

RIESGO: "Encuesta solo contesta equipo técnico de seguridad"

RESULTADO: No hay ownership ejecutivo; no hay presupuesto

SOLUCIÓN:

- └ Requiere participación de:
 - └ CFO (presupuesto, ROI)
 - └ COO (operacional, disponibilidad recursos)
 - └ CTO/CIO (infraestructura, tooling)
 - └ General Counsel (regulatorio, riesgo legal)
- └ Reuniones ejecutivas (no delegadas):
 - └ Kick-off (15 min): Por qué hacemos esto
 - └ Mid-point (30 min): Hallazgos preliminares & decisiones
 - └ Board (25 min): Resultados finales & votación presupuesto
- └ CISO es dueño; Ejecutivos son patrocinadores

5. Plan de Remediación (Roadmap Claro)

PARA CADA RIESGO IDENTIFICADO, DOCUMENTAR:

PLANTILLA DE RIESGO & REMEDIACIÓN	
Riesgo:	[Nombre, ej: "Vulnerabilidades críticas"]
Criticidad:	CRÍTICO / ALTO / MEDIO
Indicador(es):	[CIS control(es) afectado(s)]
Score actual:	[ej: 1.5 PRAGMATIC]
Target:	[ej: 2.8+]
Descripción:	[Qué es el riesgo en 2-3 sentences]
Impacto:	[Qué pasaría si no lo remedias]
Root cause:	[Por qué existe hoy]
Solución:	[Plan de acción]
Responsable:	[Nombre, departamento]
Timeline:	[Fechas hito]
Presupuesto:	[€X o "sin costo"]
Dependencias:	[Qué otros riesgos debe resolverse primero]
Evidencia éxito:	[Cómo sabemos que lo arreglamos]
Auditoría:	[Quién lo valida]

EJEMPLO REAL:

Riesgo:	SIEM False Positive Rate (32% vs target <20%)
Criticidad:	ALTO
Indicador:	MTTD (Mean Time To Detect) - score 2.4
Descripción:	SIEM genera demasiadas alertas falsas, haciendo que equipo las ignore (alert fatigue)
Impacto:	Alertas reales pueden ignorarse → breach detection se retrasa → aumenta dwell time (costo x10)
Root cause:	Reglas SIEM no tuning desde implementación (hace 2 años, antes de esta cuantificación)
Solución:	- Mes 1: Auditoría de top 50 alertas (cuáles son falsas) - Mes 1-2: Tuning de reglas (consultant SIEM 30 días) - Mes 2-3: Testing (sandbox antes de producción) - Mes 3: Monitoreo (semanal validación)
Responsable:	SOC Manager + SIEM Administrator
Timeline:	Completar antes 28 Febrero 2026
Presupuesto:	€15k (consultor SIEM temp)
Dependencias:	Ninguna
Evidencia éxito:	False positive rate <20% por 3 sem
Auditoría:	SOC Manager + CISO (biweekly reviews)

FAQ (PREGUNTAS FRECUENTES)

Q1: ¿Cuánto tiempo toma ejecutar el kit completo?

A: Depende de tamaño organizacional y complejidad:

PME (50-200 personas):

- Prep: 2 semanas
- Encuesta: 3 semanas
- Análisis: 2 semanas
- Reporte: 1 semana
- TOTAL: 8 semanas (2 meses)

Enterprise (1000+ personas):

- Prep: 3 semanas (más stakeholders)
- Encuesta: 4 semanas (distribuida por regiones)
- Análisis: 3-4 semanas (más datos, más revisión)
- Reporte: 2 semanas (board process)
- TOTAL: 12-14 semanas (3-3.5 meses)

Sector crítica (infraestructura):

- Prep: 4 semanas (regulatorio, abogados)
- Encuesta: 6 semanas (multi-sitio, auditoría simultánea)
- Análisis: 4 semanas (independencia requerida)
- Reporte: 3 semanas (junta directiva, aprobaciones)
- TOTAL: 17-20 semanas (4-5 meses)

Q2: ¿Necesitamos consultor externo?

A: Depende de capacidad interna:

SÍ necesitan consultor IF:

- Equipo de seguridad muy pequeño (<3 FTE)
- Primera vez implementando GQM + PRAGMATIC
- Necesitan auditoría independiente (regulatorio)
- Presupuesto disponible (€10-30k consultant)
- Timeline es crítico (acelera proceso)

NO necesitan consultor IF:

- CISO senior con experiencia en frameworks
- Equipo establece de 5+ personas
- Budget limitado (prioritizar herramientas)
- Timeline flexible (auto-ejecutable en 12-16 semanas)
- Benchmarks internos vs externos menos importantes

Q3: ¿Qué pasa si hallamos que somos muy atrasados (IGM <40%)?

A: No es "malo"; es "diagnóstico". Acción recomendada:

SEMANA 1: NO ENTRAR EN PÁNICO

- └ IGM <40% es común en primera medición
(especialmente si antes no había framework)

SEMANA 2: Entender por qué

- └ ¿Es falta de inversión (presupuesto)?
- └ ¿Es falta de conocimiento (skill gap)?
- └ ¿Es falta de prioridad (no es importante)?
- └ ¿Es debilidad fundamental (arquitectura)?
- └ Cada causa → diferente solución

SEMANA 3-4: Plan de mejora

- └ Fase 1 (3 meses): 5-7 indicadores críticos
 - └ Enfoque: Riesgos CRÍTICOS que pueden mitigar rápido
 - └ Ejemplo: MFA (semanas), SIEM basic (4 semanas), etc.
- └ Fase 2 (6 meses): 8-12 indicadores adicionales
 - └ Enfoque: Riesgos ALTOS + básicos de cumplimiento
- └ Fase 3 (12 meses): 25+ indicadores
 - └ Enfoque: Optimización + innovación

ROADMAP:

Hoy (IGM 35%) — Mes 3 — Mes 6 — Mes 12
 35% → 55% → 70% → 85%

Con plan ejecutado correctamente

Q4: ¿Cómo interpretar si nos dicen somos "peor que peers"?

A: Benchmarking es referencia, no veredicto:

NO SIGNIFICA:

- └ Que somos "malos" o "ineptos"
- └ Que necesitamos copiar exactamente qué hacen otros
- └ Que nuestro sector específico es malo

SÍ SIGNIFICA:

- └ Hay gaps identificables vs líderes del sector
- └ Otras organizaciones similares han resuelto estos problemas
- └ Hay aprendizaje disponible de sus experiencias

ACCIÓN RECOMENDADA:

- └ Estudiar cómo los peer líderes implementaron indicador
- └ Adaptar a nuestro contexto (no copiar-pegar)
- └ Aprender lecciones: qué funcionó, qué no
- └ Proyectar: si adoptamos X, cuándo alcanzamos benchmark?

EJEMPLO:

"Nuestro MTTD es 24h, benchmark es 4h"

- └ ¿Por qué 6x diferencia?
 - └ Herramientas (SIEM más avanzado)
 - └ Equipo (más analysts)
 - └ Procesos (automatización)
 - └ Datos (volumen y complejidad)
- └ Si invertimos en SOAR (€40k), alcanzamos 8h en 6 meses
- └ Si invertimos en más personal (€60k/año), alcanzamos 6h
- └ Elegir basado en ROI, no en "necesidad" de benchmark
- └ Target es contexto: 4h para líderes, 12h es OK para PYME

Q5: ¿Cada cuánto repetimos la encuesta?

A: Recomendación por frecuencia y profundidad:

ENCUESTA COMPLETA (45+ indicadores):

- Frecuencia: Anual (mejor) o biannual
- Esfuerzo: 4-6 semanas
- Objetivo: Medición completa de madurez
- Cuándo: Después de board meeting; antes de budget planning
- Resultado: Nuevo IGM baseline, comparativa año-a-año

ENCUESTA PARCIAL (Top 10-15 indicadores críticos):

- Frecuencia: Trimestral
- Esfuerzo: 1-2 semanas
- Objetivo: Tendencia rápida de indicadores clave
- Cuándo: Antes de board report trimestral
- Resultado: Dashboard updatado; alertas si drift

MONITOREO AUTOMÁTICO (5 indicadores operacionales):

- Frecuencia: Semanal / Real-time
- Esfuerzo: Automatizado (no manual)
- Indicadores: MTTR, MFA coverage, Vulns críticas, MTTR, Phishing %
- Fuente: SIEM, IAM, Scanner logs (directo)
- Resultado: Dashboard vivo; alerts automáticas si salen de range

EJEMPLO CALENDAR:

ENERO	Encuesta completa (2026 baseline)
ABRIL	Encuesta parcial (top 10 + board)
JULIO	Encuesta parcial (top 10 + board)
OCTUBRE	Encuesta completa (año-a-año comparativa)
DIARIO	5 KPIs automáticos en dashboard

Q6: ¿Qué hacemos si equipo de seguridad rechaza los resultados?

A: Legítimo; probablemente hay desalineamiento:

PASO 1: Escuchar sin defensiva

- └ "¿Por qué crees que tu score debería ser diferente?"
- └ "¿Cuál es la evidencia?"
- └ "¿Qué interpretación diferente tienes de la pregunta?"

PASO 2: Calibración adicional

- └ Invitar a sesión de revisión (no confrontación)
- └ Traer evidencia (logs, documentación)
- └ Ajustar score si hay razón válida
- └ Documentar la conversación (para auditoría)

PASO 3: Comunicar que desacuerdo existe

- └ Si equipo insiste en score más alto pero evidencia no apoya:
 - └ Seleccionar score conservador (con nota de "disputed")
- └ Si hay interpretación legítima diferente de pregunta:
 - └ Incorporar feedback en versión siguiente de encuesta
- └ Nunca falsificar datos por "peace"; eso invalida todo

EJEMPLO REAL:

PREGUNTA: "¿Cuánto % de vulnerabilidades críticas remediadas <7 días?"

RESPUESTA EQUIPO: "100% (decimos que sí)"

EVIDENCIA: Logs de scanner muestran 7 vulns aún abiertos >7 días

- └ RESOLUCIÓN: Documentar las 7 excepciones
 - Aclarar: "100% de nuestro proceso"; estas 7 no
 - Ajustar score de "3" → "2" con nota explicativa

Q7: ¿Cómo manejamos si resultados muestran culpa de ejecutivo específico?

A: Métricas no son "culpa"; son "oportunidad":

LENGUAJE IMPORTANTE:

- └ NO: "El VP IT falló en implementar MFA"
- └ SÍ: "Oportunidad: MFA coverage 85% → target 95%"
- └ Reason: MFA depende de múltiples factores (herramientas, procesos, user adoption, budget). Simplificar a "culpa" desincentiva ownership

POLÍTICA RECOMENDADA:

- └ Métricas se usan para MEJORA, no para castigo
- └ Resultados bajos pueden resultar en:
 - └ Presupuesto adicional (no reducción)
 - └ Apoyo adicional (recursos, consultores)
 - └ Reconocimiento de mejora (si se arregla)
- └ Nunca: Reducción de salario, rebaja, rotación

POLÍTICA SOBRE MEJORA:

- └ Quien reconoce problema y lo aborda → reconocimiento positivo
- └ Quien esconde o niega problema → riesgo reputacional
- └ Esto crea cultura donde la gente reporta honestamente

BENEFICIO A LARGO PLAZO:

- └ Mejor seguridad real (vs. números bonitos en encuesta)

CONTACTOS Y SOPORTE

Si necesitas ayuda:

PREGUNTAS TÉCNICAS (Metodología GQM/PRAGMATIC):

- └ Consulta Documento 1 (Marco Integrativo)
- └ Email: security-metrics@org

PREGUNTAS SOBRE INDICADORES:

- └ Consulta Documento 2 (Matriz PRAGMATIC)
- └ Email: security-metrics@org

PREGUNTAS SOBRE COMPLIANCE:

- └ Consulta Documento 3 (Mapeo Normativo)
- └ Email: compliance@org

PREGUNTAS SOBRE CÁLCULOS EXCEL:

- └ Consulta Documento 4 (Plantilla Excel)
- └ Email: finance-security@org

PREGUNTAS SOBRE PRESENTACIÓN:

- └ Consulta Documento 5 (PowerPoint)
- └ Email: ciso@org

PREGUNTAS GENERALES:

- └ Este README (Documento 6)
- └ Email: security-metrics@org

ESCALACIÓN SI BLOQUEADO:

- └ CISO directo (si tema urgente)
- └ Security Steering Committee (si decisión needed)
- └ Board audit committee (si aprobación needed)

VERSIONAMIENTO Y ACTUALIZACIONES

Versión 1.0 (Enero 2026):

- └ Lanzamiento inicial
- └ 45+ indicadores CIS Controls v8.1
- └ Alineación NIS2, GDPR, ISO 27001, regulaciones España

Actualizaciones esperadas:

- └ Semestral: Nuevos indicadores, benchmarks actualizados
- └ Anual: Cambios en normativas (ej: nueva versión NIST CSF)
- └ Continuo: FAQ, lecciones aprendidas de implementaciones
- └ Contactar: Enviar feedback a security-metrics@org

Cambios importantes (registrar):

- └ Si normativa cambia → Documento 3 (Mapeo Normativo)
- └ Si nuevos indicadores adoptados → Documento 2 (Matriz)
- └ Si metodología mejora → Documento 1 (Marco GQM/PRAGMATIC)
- └ Si datos de ROI se revisan → Documento 4 (Excel)

BIENVENIDO AL KIT. ¡ÉXITO CON TU EVALUACIÓN DE CIBERSEGURIDAD!